

Spec Grader Report

AI-Led Automation Initiative — Specification Evaluation

Document	AI Fluency Assessment Application — Technical Specification v1.5
Owner	Marion Kaehlke, Chief People Officer
Date	11 June 2026
Tier	Tier 3 (Spec Doc Full)
Tier Rationale	Employee PII sent to an external model API plus automated AI scoring in an employment context place this firmly in Tier 3, even though blast radius is internal — the data sensitivity and EU AI Act exposure are the deciding factors.
Evaluator	Spec Grader v4.0

Headline

Overall Weighted Score	2.90 / 3.00
Grade Band	BUILD-READY
Automatic Disqualification	None — Edge Cases scored 3/3

This is the strongest version of this spec to date — a decisive move out of the earlier ‘Significant Gaps’ band into Build-Ready. The failure-mode catalogue, security/compliance treatment, and builder-context appendix are now genuinely comprehensive. The two remaining 2/3 dimensions (User Experience, Integrations) are the only material headroom, and neither is a build blocker.

Dimension Scores

Dimension	Score	Weight	Weighted	Key Gap / Note
1. Strategic Rationale	3/3	8%	0.24	Quantified ROI leans on an external benchmark; Phrase L&D budget figure not stated
2. Process Coverage	3/3	15%	0.45	End-to-end across all three surfaces; edge paths fully routed
3. Data Model	3/3	10%	0.30	Complete entities, Personio join key, retention; per-field validation table not exhaustive
4. Business Logic	3/3	15%	0.45	Composite calc, role precedence, calibration gate; worked examples present

Dimension	Score	Weight	Weighted	Key Gap / Note
5. Edge Cases	3/3	15%	0.45	§7a catalogue is exemplary across all failure modes
6. User Experience	2/3	5%	0.10	Flows and error states defined; no accessibility considerations
7. Integrations	2/3	5%	0.10	Anthropic spec is full; Personio API deferred to Phase 2 (CSV in MVP)
8. Data & Security	3/3	10%	0.30	PII, DPA, zero-retention, LIA, EU AI Act, prompt injection all addressed
9. Tech Stack	3/3	7%	0.21	Complete stack, versions, secrets, observability, Launchpad skills
10. Validation	3/3	7%	0.21	Baselines, shadow-mode gate, go/no-go, rollback all specified
11. AI Buildability	3/3	3%	0.09	§12.4 is a full CLAUDE.md spec with anti-patterns and coverage targets
Overall Score	2.90	/ 3.00		

Grade

BUILD-READY (2.50 to 3.00). This spec clears the bar for TechOps, Security and Legal approval. A skilled engineer or AI coding agent could build a production system from it with very few clarifying questions. No automatic disqualification applies: the system has write-side effects and AI-assisted scoring, but Edge Cases and Error Handling (Dim 5) scores 3 out of 3, well clear of the 0-to-1 disqualification trigger.

Important: Build-Ready is not the same as cleared-to-flow-data. Several launch gates in §10.4 are hard, blocking, and externally owned — Anthropic DPA execution, the documented LIA, and the EU AI Act classification recorded in the AI Register. These are correctly identified in the spec as Go/No-Go criteria; they are governance prerequisites, not spec defects.

Detailed Feedback by Dimension

1. Strategic Rationale & Business Case — 3/3

Strengths: §1.4 is a complete business case: build cost (~€35k first year), cost of inaction quantified in People Ops hours (~120–180 hrs/cycle), value framing, explicit OKR alignment, and a real alternatives table.

To improve: The L&D-efficiency value rests on an external ‘20–30% misdirected spend’ benchmark without stating Phrase’s actual L&D budget, so the headline ‘justifies the build in

Year 1' claim is directional rather than computed. Not a blocker — add the budget figure to make the ROI self-contained.

2. Process Coverage — 3/3

Strengths: Every surface (Employee, Manager, ELT) is mapped trigger-to-outcome, with as-is (Cowork) vs to-be contrast. The edge paths in §4.4 — no-manager calibration, MVP email notification, abandoned-draft cleanup, offboarding — are the kind of routing detail most specs omit.

To improve: No material gap. The CPeO-as-calibrator path (ADMIN_CALIBRATOR) is well handled, including its audit-log treatment.

3. Data Model — 3/3

Strengths: Five entities with fields, types, relationships, the Personio email join key, UNASSIGNED/null defaults, and a reconciliation report for unmatched users. Retention and anonymisation rules are explicit.

To improve: A per-field validation/update-frequency matrix isn't laid out exhaustively (e.g. freshness of functionArea between logins). Low risk given login-time resolution, but worth a line.

4. Business Logic & Decision Rules — 3/3

Strengths: Composite calculation, level-mapping table (§12.2), role-resolution precedence, the calibration gate, and scoring cache logic are all testable. The §12.5.1 worked examples (including an L1-vs-L2 boundary case) are excellent calibration material.

To improve: No material gap. The 'when in doubt default to L1' tie-breaker is the kind of explicit conflict-resolution rule the rubric rewards.

5. Edge Cases & Error Handling — 3/3

Strengths: §7a is the standout. It enumerates network/timeout/5xx, malformed model output (with Zod schema), the hallucination human-gate, concurrency/double-submit (optimistic lock + Redis distributed lock + idempotency), auth edge cases, and a full user-facing error-message table.

To improve: No material gap. This dimension alone moves the spec out of the disqualification zone for a write-capable system.

6. User Experience & Interaction Model — 2/3

Strengths: Key flows, screen states, loading/error banners, and role-based views are specified. The 'AI suggestion — review with your manager' labelling is well placed.

To improve: Accessibility is absent — no WCAG target, keyboard-navigation, or screen-reader considerations for a tool every one of ~300 employees must use. Input validation rules are stated (min/max char counts) but not the full set of field-level validation messages. Adding an accessibility line and an empty-state spec would lift this to 3.

7. Integration Specifications — 2/3

Strengths: The Anthropic integration (§7.4) is a model of completeness: pinned model string, version header, params, retry, circuit-breaker thresholds, and cost ceiling. Google OAuth PKCE flow is fully specified.

To improve: Personio — the system of record for the entire role model — has no endpoint, auth, schema, rate-limit, or failure-handling detail because the API integration is deferred to Phase 2 (MVP uses CSV import). That deferral is acknowledged, so it doesn't count as an unhandled gap, but the dimension can't score 3 while a load-bearing integration is unspecified. Define the Personio API contract before the Phase 2 build.

8. Data & Security Declaration — 3/3

Strengths: For a high-sensitivity initiative this is comprehensive: PII classified, data minimisation (no PII in API payload beyond free-text), Anthropic DPA + zero-retention + SCCs, GDPR legitimate-interest basis with LIA action, EU AI Act classification with a hard DPO gate, a dedicated prompt-injection control section, and a full data-subject-rights table.

To improve: The EU AI Act 'not high-risk' finding is well argued but load-bearing and self-assessed; the spec correctly routes it to independent DPO confirmation as a blocking gate. Keep that framing tight — any scope creep toward performance/promotion use re-triggers high-risk classification.

9. Technology Stack & Tooling — 3/3

Strengths: Full stack with versions, the Launchpad skill chain, secrets inventory, and the Grafana/Loki/Mimir observability path. A compliance officer can trace data through every tool.

To improve: No material gap.

10. Validation & Success Criteria — 3/3

Strengths: Pilot baselines, a shadow-mode methodology with a quantified >80% exact-match gate, eight owner-assigned Go/No-Go criteria, and a step-by-step rollback (feature-flag, 30-min RTO, zero data loss) with measurable triggers.

To improve: No material gap. This is what a validation framework should look like.

11. AI Agent Buildability — 3/3

Strengths: §12.4 specifies the CLAUDE.md content directly: purpose, architecture, critical scoring rules, naming conventions, an anti-patterns table, and tiered test-coverage targets. It even names the docx WidthType.PERCENTAGE pitfall.

To improve: No material gap. Establish this as the portfolio standard.

Top Priority Gaps

None of these are build blockers — the spec is approvable as written. They are the highest-value refinements plus the externally-owned launch gates that must close before data flows.

1. Execute the Anthropic DPA & confirm zero-retention (Dim 8 / §8.4, §10.4 #2)

This is a hard, blocking launch gate and a recurring blocker across every Claude-API project in the portfolio. Resolve at portfolio level, not per-project. Owner: Legal / DPO + Engineering lead. Resolution: signed DPA on file, zero-retention verified in account settings, evidence attached to the launch record.

2. Confirm & record the EU AI Act classification (Dim 8 / §10.4 #4)

The 'not high-risk / development tool' finding is sound but self-assessed and load-bearing. DPO must independently confirm and log it in the AI Register before any employee data flows.

Resolution: AI Register entry signed off by DPO; CPeO owns re-assessment trigger if scope expands.

3. Document the Legitimate Interest Assessment (Dim 8 / §8.4, §10.4 #3)

Legitimate interest is the correct GDPR basis, but the LIA must be written and DPO-approved, with the 'not a performance gate' framing as the core mitigation. Resolution: signed LIA on file.

4. Specify the Personio API integration contract (Dim 7 / §10.2)

The role model depends on Personio, yet the API is unspecified pending Phase 2. Before the Phase 2 build, define endpoints, auth, the email-join schema, rate limits, and sync-failure handling. Resolution: a Personio integration sub-spec mirroring the §7.4 Anthropic treatment.

5. Add accessibility & empty-state coverage (Dim 6 / §4)

A tool mandatory for all ~300 staff needs at least a WCAG 2.1 AA target, keyboard/screen-reader notes, and empty-state behaviour. Resolution: a short accessibility subsection plus field-level validation messages.

Questions the Builder Will Ask

Integrations (Personio): What is the exact Personio endpoint and auth method for resolving managerId / functionArea by email? What is the rate limit, and what happens if Personio is unreachable at login — fail the login, or fall back to the last-known CSV value?

User Experience: What is the target accessibility standard, and are there keyboard-only and screen-reader requirements? What does each surface show in its empty state (e.g. a manager with zero submitted reports; an ELT dashboard before any cycle completes)?

Data Model: How fresh must functionArea be — is login-time resolution sufficient, or is mid-session re-sync ever needed? For a mid-cycle manager change in Personio, does an in-flight calibration stay with the original manager?

Business Case: What is the actual annual Phrase L&D enablement budget the 20% efficiency claim is applied to? This converts the ROI from directional to computed.

Security / Compliance: Once zero-retention is enabled, what is the verification artefact the engineering lead attaches to the launch record? Who is the named DPO for the LIA and AI Register sign-off?

Legal & Security Sign-Off Summary

This initiative involves elevated data (employee PII, an external model API, automated AI-assisted scoring in an employment context). A full sign-off briefing is required.

1. Initiative Overview

An internal web application for ~300 Phrase employees to self-assess AI fluency (L0–L4 across four dimensions). Claude scores free-text responses as suggestions only; a manager confirms the final level in a 1:1. Three role-gated surfaces (Employee, Manager, ELT) are deployed on Phrase Launchpad with Google SSO and Personio as the org-structure source of truth.

2. Data Classification Summary

Data Element	Classification	Source → Destination	Crosses Org Boundary?
Employee free-text responses	PII (personal data)	Browser → Phrase DB → Anthropic API	Yes — to Anthropic (US)
Name, email	PII	Google OAuth → Phrase DB	No (not sent to model)
Manager ID, function area	Internal Confidential	Personio → Phrase DB	No
AI-suggested & agreed levels	Internal Confidential	Phrase DB; anonymised in exports	No
Audit log (actor, action, ts)	Internal Confidential	Phrase DB	No

Data minimisation confirmed: only the four dimension responses and the opening reflection are sent to Anthropic. No name, email, manager identity, or function is included in any API payload (§8.4).

3. Third-Party Systems & Data Exposure

System	Data Shared	Legal Agreement	Review Status
Anthropic Claude API	Employee free-text responses (PII)	DPA + SCCs (Modules 2 & 3)	BLOCKING — DPA must be executed pre-launch
Google Workspace	OAuth identity (email) only	Existing Workspace agreement	Standard — in place
Personio (HRIS)	Read of managerId / functionArea	Existing HRIS agreement	Confirm read-only API scope
Launchpad SMTP relay	Manager email + employee name in notification	Internal (no new processor)	OK — chosen to avoid new DPA

4. AI-Specific Risks

Data sent to model: employee free-text only, no identifiers. **Provider retention:** zero-retention to be enabled and verified pre-launch. **Prompt injection:** mitigated by instruction/data isolation (system vs user message), input length validation, and Zod output validation (§8.4).

Hallucination in a decision-critical path: mitigated by a mandatory human gate — agreedLevel requires manager_confirmed: true; compositeLevel never derives from AI scores.

Automated decision-making: none in the GDPR Art. 22 sense — every score is human-confirmed.

5. Security Baseline Deviations

No significant deviations. The application inherits the Launchpad baseline (SSO, secrets management, encryption at rest, observability). The one deliberate design choice — SMTP

relay instead of a third-party email processor — reduces rather than expands the processor footprint and is the more conservative option.

6. Compliance Checklist

Item	Status
GDPR lawful basis identified	Yes — Legitimate Interest, Art. 6(1)(f); LIA pending DPO approval
Data Processing Agreements required	Anthropic (BLOCKING). Google & Personio existing.
Data residency requirements met	Conditional — EU→US transfer on SCCs; DPO to confirm adequacy
Data subject rights accommodated	Yes — full Art. 15/16/17/21/22 mapping in §8.4
Audit logging for sensitive operations	Yes — score confirmations, flags, exports logged with actor + timestamp
EU AI Act classification recorded	Pending — DPO must log in AI Register (BLOCKING gate #4)

7. Recommended Actions Before Build

- Legal/DPO: execute the Anthropic DPA and confirm SCC adequacy for the EU→US transfer.
- DPO: document and approve the LIA; independently confirm and record the EU AI Act classification in the AI Register.
- Engineering lead: enable and verify Anthropic zero-retention; attach evidence to the launch record.
- People Ops/Engineering: confirm read-only Personio API scope for the Phase 2 integration.

8. Sign-Off Required From

- Petra (Legal & Compliance) — DPA execution, SCC adequacy
- IT Security — secrets handling, Launchpad baseline confirmation
- Data Protection Officer — LIA approval and EU AI Act classification (blocking)
- Marion Kaehlke, CPeO — ELT seed list and People Ops sign-off

Revision Checklist

The spec is approvable as written. The following are the pre-launch governance gates (externally owned) plus optional refinements. None block engineering assignment.

Build / Launch Blockers (externally owned, already identified in §10.4)

- ☐ Execute Anthropic DPA and verify zero-retention is enabled.

- ☐ Document and obtain DPO approval of the Legitimate Interest Assessment.
- ☐ Record the EU AI Act classification in Phrase's AI Register (DPO confirmation).
- ☐ Confirm SCC adequacy for the EU→US data transfer.

Recommended Improvements (non-blocking)

- ☐ Add Phrase's actual L&D budget figure to §1.4 to make the ROI self-contained.
- ☐ Add an accessibility subsection (WCAG 2.1 AA target, keyboard/screen-reader notes) to §4.
- ☐ Specify empty-state behaviour for each surface and the full set of field-level validation messages.
- ☐ Add a per-field freshness/validation note for functionArea in §6.
- ☐ Draft the Personio API integration sub-spec (endpoints, auth, schema, rate limits, failure handling) ahead of the Phase 2 build.

Generated by Spec Grader v4.0 — evaluated against the Tier 3 (Spec Doc Full) rubric, 11 weighted dimensions.